SMB — Generalised Playbook

ISEC6005 · works on ANY SMB box · all the ways SMB yields a flag (incl. ones not practised) · v4

How to use

- nmap shows **139/445**. Walk the tree; it covers every SMB path. Ignore default shares (C$/ADMIN$/IPC$/print$); target the custom one.

1. Concept

What SMB is

- **SMB** shares folders ('shares') over a network. **Null/anonymous session** (no user/pass) being allowed is the usual weakness.
- **Default shares** C$/ADMIN$/IPC$/print$ = ignore. A **custom** named share = your target.
- SMB can also be **exploited** directly (old versions) or give **users** for password attacks.

2. Decision tree (covers every SMB flag path)

```
nmap shows 139/445
  |
  v  smbclient -L //<IP> -N      (list shares anonymously)
  |
  +-- custom share listed? --NO--> enum4linux -a <IP> (hidden shares/users);
  |                                  or SMB not the way; or exploit old SMB (searchsploit)
  YES
  |
  v  smbclient //<IP>/<share> -N  ;  recurse ON; ls
  |
  +-- flag file?        -> get + cat                          = EASY FLAG
  +-- note/creds file?  -> read it (feeds the next step)      = Easy->Intermediate
  +-- writable share?   -> upload payload / scheduled path    = Intermediate/Hard
  +-- users found?      -> (enum4linux) password-spray / crack= Intermediate
  +-- only defaults?    -> try the WEB or FTP service instead
```

3. Core commands & enumeration tools (explained)

Command / tool	What it does	When
smbclient -L //IP -N	list share names anonymously	first look
smbclient //IP/<share> -N	open one share interactively	to read files
recurse ON; ls	list all files in all subfolders	inside a share
get / more <file>	download / read a file	to grab flag/notes
enum4linux -a IP	full sweep: shares, users, OS, domain, policy	when -L is thin
smbmap -H IP	read/write access level per share	to find a writable share
nmap --script smb-enum-shares -p445 IP	enumerate shares via nmap (backup)	if smbclient errors
smbclient //IP/<share> -U user%pass	connect WITH credentials	when anon denied + you have creds

4. All the ways SMB gives a flag

Variation	What you do	Stage

Anonymous read of a flag file	get + cat	Easy
Anonymous read of a creds/clue file	reuse for the next login (web/SSH/DB)	Easy->Inter
Writable share	upload a payload or poison a path	Intermediate/Hard
User list via enum4linux	password-spray or crack, then login	Intermediate
Credentialed access (creds found elsewhere)	-U user%pass -> more shares/files	varies
Vulnerable SMB version	searchsploit (e.g. known SMB RCE) — confirm version	Inter/Hard

Adapting to a box you have NOT seen

- Unknown/old SMB? `nmap -sV` gives the version; `searchsploit` it — some SMB versions have famous RCEs (confirm the version first).
- Only default shares? SMB probably isn't the route — pivot to the web or FTP service.
- Anonymous denied? Find creds elsewhere, then `-U user%pass`. Or enum4linux for a user list to spray.
- Found a writable share? That's a foothold — think about what reads from it (a web root, a scheduled task).

WRITE YOUR REPORT — SMB

If this technique comes up, you can write the whole report from here. Fill the <...> blanks with your box's real values and keep the structure.

Step 1 — pick the vulnerability that matches what you found

Vulnerability (use this name)	When it applies	Severity
Anonymous / Null-Session SMB Share	A share is readable with -N (no credentials).	High
Sensitive Data Exposure via SMB	Files on the share contain creds, configs, backups or the flag.	High
Writable SMB → RCE	You can upload to a share that feeds a web root or scheduled task.	Critical

Step 2 — Executive Summary (non-technical, for management)

Model — adapt the <...>

- During the authorised penetration test of <system name>, the SMB service (ports 139/445) was found to expose a non-default file share that could be accessed anonymously, using a null session with no username or password. An unauthenticated attacker on the network could browse the share and read its contents, including <describe what was exposed: documents, configuration, credentials, the flag>. This discloses confidential information to any user who can reach the service. The root cause is an SMB share configured to allow guest / anonymous access. The overall risk is rated <High> and remediation should be prioritised.

Step 3 — Detailed Finding(s) (the core of the report)

Finding: Anonymous SMB Share Access & Sensitive Data Exposure — **Severity:** High (CVSS ~7.5)

Description (cause + trust assumption): The host exposes a custom SMB share (<share name>) that permits anonymous / null-session access, so no credentials are required to connect and read files. **Cause:** the share was configured with guest access enabled (and/or anonymous enumeration not restricted), and sensitive files were placed on it. **Trust assumption violated:** the share assumed only authorised domain users would connect, but enforced no authentication, exposing the data to anyone on the network.

Evidence (commands run — attach screenshots of each):

```
nmap -p139,445 -sV <TARGET_IP> # SMB open (Windows)
smbclient -L //<TARGET_IP>/ -N # list shares -> <share> (non-default)
```

```
smbmap -H <TARGET_IP> # shows READ/WRITE perms per share
smbclient //<TARGET_IP>/<share> -N # connect with null session
smb: \> ls ; get <file> # download sensitive file
cat <file> # -> <creds / flag>
```

Impact (blast radius + business): Blast radius: everything on the share is readable — not only the flag but any document, backup, script or credential stored there; recovered credentials frequently unlock SSH, WinRM (5985) or RDP (3389) and let the attacker pivot. A writable share that feeds a web root or scheduled task escalates to remote code execution. **Business impact:** unauthorised disclosure of confidential data and a likely stepping stone to full host compromise, with the usual breach, reputational and compliance fallout.

Recommendation (mitigation): Disable guest / anonymous access on the share (`guest ok = no`); set `restrict anonymous = 2` on Windows to stop null-session enumeration; apply least-privilege share and NTFS permissions so only named accounts can read; remove sensitive files from shares; patch SMB and disable SMBv1; segment the network so the service is not broadly reachable.

Verification after fix: Re-run `smbclient //<TARGET_IP>/<share> -N` — the null session should be rejected (NT_STATUS_ACCESS_DENIED). Confirm the share now requires valid credentials and the sensitive file is no longer readable anonymously.

Step 4 — Attack Path Summary (one line per step)

```
1. nmap -p139,445 -sV <TARGET_IP> -> SMB open
2. smbclient -L //<TARGET_IP>/ -N -> non-default share visible
3. smbclient //<TARGET_IP>/<share> -N -> null session connects
4. ls / get <file> -> retrieved sensitive file
5. cat <file> -> easy flag / credentials
6. (if creds) evil-winrm/ssh/rdp -> intermediate flag
```

Step 5 — Remediation Plan (prioritised)

- **Immediate:** set `guest ok = no` on the share; remove sensitive files from it.
- **Short term:** `restrict anonymous = 2`; apply least-privilege share + NTFS ACLs; disable SMBv1.
- **Long term:** patch and baseline SMB, segment the network, and monitor share-access logging.

Step 6 — Conclusion

Model — adapt the <...>

- The SMB service exposed a share to anonymous users, disclosing confidential data without authentication. The issue is simple to exploit yet has serious confidentiality impact and provides a realistic foothold for lateral movement. Requiring authentication and least-privilege access on the share closes the gap. Testing remained within the agreed scope and no files were modified or deleted.